

Vulnerability Assessment & Reconnaissance Report

Target: http://127.0.0.1:8000

GENERATED
2026-09-12T12:00:45

DURATION
1.85s

OVERALL RISK
HIGH

Table of Contents

- 1. Assessment Scope & Authorization
- 2. Executive Summary
- 3. Attack Surface Overview
- 4. DNS Reconnaissance
- 5. RDAP / WHOIS
- 6. Subdomain Enumeration
- 7. Port & Service Enumeration
- 8. HTTP/HTTPS Reconnaissance
- 9. TLS Analysis
- 10. Technology Fingerprinting
- 11. Web Crawl
- 12. Endpoint & Parameter Discovery
- 13. JavaScript Analysis
- 14. Directory / Content Discovery
- 15. Security Headers & Cookies
- 16. Vulnerability Findings
- 17. CVE Correlation
- 18. Methodology

Assessment Scope & Authorization

Field	Value
Target	http://127.0.0.1:8000
Authorization	Confirmed by operator prior to scan execution
Scan started	2026-09-12T12:00:43
Scan finished	2026-09-12T12:00:45
Duration	1.85s
Modules executed	dns_recon, rdap, port_scanner, http_recon, technology_fingerprint, web_crawler, js_analyzer, endpoint_discovery, directory_bruteforce, vulnerability_scanner, cve_correlator

Executive Summary

This report presents automated reconnaissance and vulnerability-indicator results for **http://127.0.0.1:8000**, produced by AutoVAPT. All indicator-based findings require manual verification by a qualified tester before being treated as confirmed vulnerabilities.



Overall risk rating: High (weighted score: 26.2)

Attack Surface Overview

Metric	Value

Resolved IPv4	127.0.0.1
Subdomains discovered	0
Open ports	1
Pages crawled	3
Forms found	1
Endpoints found	10
Directories found	4
Technologies identified	
Total security findings	10

DNS Reconnaissance

Record	Value(s)
IPv4	127.0.0.1
IPv6	—
CNAME	—
MX	—
NS	—
TXT	—
SOA	—

Reverse DNS

IP	Hostname
127.0.0.1	localhost

No dig/host/nslookup found - only A/AAAA records available. Install `dnsutils` (dig/host) for full record types.

RDAP / WHOIS

RDAP lookup failed and `whois` binary not found/failed. Install `whois` package for registrar-level detail.

Subdomain Enumeration

Subdomain enumeration not run.

Port & Service Enumeration

Engine: `python-socket` (stdlib) | Spec: `7990-8010`

Port	Proto	Service	Product	Version	Banner
8000	tcp	http-alt			

HTTP/HTTPS Reconnaissance

Working base URL: http://127.0.0.1:8000

HTTPS

Field	Value
Status	None
Final URL	None
Title	
Content-Length	0
Response time	0.6 ms
Error	URLError: [SSL: WRONG_VERSION_NUMBER] wrong version number (_ssl.c:1000)

HTTP

Field	Value
Status	200
Final URL	http://127.0.0.1:8000
Title	AutoVAPT Lab Target
Content-Length	343
Response time	0.9 ms
Error	-

robots.txt: Found (HTTP 200)

sitemap.xml: Not found (HTTP 404)

security.txt: Not found (HTTP 404)

TLS Analysis

TLS analysis not run.

Technology Fingerprinting

No technologies identified with sufficient evidence.

Web Crawl

3 pages crawled (max_pages=10, max_depth=2)

URL	Status	Depth
http://127.0.0.1:8000	200	0
http://127.0.0.1:8000/about	200	1
http://127.0.0.1:8000/admin	200	1

Endpoint & Parameter Discovery

URL	Method	Source	Parameters
/admin	GET	robots.txt	

/api/	GET	robots.txt	
/api/v1	GET	javascript:http://127.0.0.1:8000/app.js	
/auth/login	GET	javascript:http://127.0.0.1:8000/app.js	
/debug/status	GET	javascript:http://127.0.0.1:8000/app.js	
http://127.0.0.1:8000	GET	crawl	
http://127.0.0.1:8000/about	GET	crawl	
http://127.0.0.1:8000/admin	GET	crawl	
http://127.0.0.1:8000/app.js	GET	script_src	
http://127.0.0.1:8000/login	POST	html_form	username, password

JavaScript Analysis

1 JS files analyzed.

Endpoints found in JS

Path/URL
/api/v1
/auth/login
/debug/status

Directory / Content Discovery

Engine: `native (stdlib)` | 45 words tested

Path	Status	Length	Confidence
/.git/HEAD	200	21	Medium
/admin	200	56	Medium
/backup.sql	200	32	Medium
/robots.txt	200	47	Medium

Security Headers & Cookies

Security Headers

Finding	Severity
Missing Content-Security-Policy	Medium
Missing X-Frame-Options / frame-ancestors	Low
Missing X-Content-Type-Options	Low
Missing Referrer-Policy	Info
Missing Permissions-Policy	Info

Cookie Security

Finding	Severity
Cookie 'session' missing security attribute(s): HttpOnly, SameSite	Low

Vulnerability Findings

AVAPT-0001: Missing Content-Security-Policy Medium confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

CSP mitigates XSS/data-injection impact; absence alone is not exploitable but raises the impact ceiling of any injection found elsewhere.

Evidence: Header 'Content-Security-Policy' absent from response to `http://127.0.0.1:8000`

Remediation: Add the 'Content-Security-Policy' header at the web server or reverse-proxy layer.

Manual verification required: No

AVAPT-0002: Missing X-Frame-Options / frame-ancestors Low confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

Increases clickjacking risk on pages with sensitive actions (e.g. forms, buttons).

Evidence: Header 'X-Frame-Options' absent from response to `http://127.0.0.1:8000`

Remediation: Add the 'X-Frame-Options' header at the web server or reverse-proxy layer.

Manual verification required: No

AVAPT-0003: Missing X-Content-Type-Options Low confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

Without 'nosniff', some browsers may MIME-sniff responses, enabling content-type confusion.

Evidence: Header 'X-Content-Type-Options' absent from response to `http://127.0.0.1:8000`

Remediation: Add the 'X-Content-Type-Options' header at the web server or reverse-proxy layer.

Manual verification required: No

AVAPT-0004: Missing Referrer-Policy Info confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

Referrer header may leak full URLs (including query params) to third parties on outbound links.

Evidence: Header 'Referrer-Policy' absent from response to `http://127.0.0.1:8000`

Remediation: Add the 'Referrer-Policy' header at the web server or reverse-proxy layer.

Manual verification required: No

AVAPT-0005: Missing Permissions-Policy Info confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

No explicit restriction on powerful browser features (camera, geolocation, etc.).

Evidence: Header 'Permissions-Policy' absent from response to `http://127.0.0.1:8000`

Remediation: Add the 'Permissions-Policy' header at the web server or reverse-proxy layer.

Manual verification required: No

AVAPT-0006: Cookie 'session' missing security attribute(s): HttpOnly, SameSite Low confidence: High

Category: Security Misconfiguration | **Affected:** `http://127.0.0.1:8000`

Cookies without Secure/HttpOnly/SameSite attributes are more exposed to interception, script access, or CSRF-style abuse.

Evidence: Set-Cookie for 'session' lacked: HttpOnly, SameSite

Remediation: Set HttpOnly, SameSite on the 'session' cookie.

Manual verification required: No

AVAPT-0007: Potentially exposed sensitive file: /.git/HEAD **High** confidence: Medium

Category: Information Disclosure | **Affected:** `http://127.0.0.1:8000/.git/HEAD`

A path commonly associated with secrets, version control metadata, or backups returned HTTP 200.

Evidence: GET /.git/HEAD -> 200, 21 bytes

Remediation: Remove from the web root or block via server configuration; rotate any credentials that may have been exposed.

Manual verification required: Yes

AVAPT-0008: Potentially exposed sensitive file: /backup.sql **High** confidence: Medium

Category: Information Disclosure | **Affected:** `http://127.0.0.1:8000/backup.sql`

A path commonly associated with secrets, version control metadata, or backups returned HTTP 200.

Evidence: GET /backup.sql -> 200, 32 bytes

Remediation: Remove from the web root or block via server configuration; rotate any credentials that may have been exposed.

Manual verification required: Yes

AVAPT-0009: Potential Reflected XSS Indicator **Medium** confidence: Low

Category: Injection (A03:2021) | **Affected:** `http://127.0.0.1:8000/?q=%3Cavaptmarker123%3E`

A harmless marker string included in a query parameter was reflected, unencoded, in the response body. This is an indicator only - it does not confirm script execution.

Evidence: Marker 'avaptmarker123' found reflected in response to `http://127.0.0.1:8000/?q=%3Cavaptmarker123%3E`

Remediation: Ensure all user-controlled input is output-encoded for its context (HTML, attribute, JS) before rendering.

Manual verification required: Yes

AVAPT-0010: Potential SQL Injection Indicator (error-based) **Medium** confidence: Low

Category: Injection (A03:2021) | **Affected:** `http://127.0.0.1:8000/?id=1%27`

A single-quote character in a query parameter triggered what appears to be a database error signature. This is an indicator only - not a confirmed SQL injection.

Evidence: Database error signature 'sql syntax' observed after quote injection at `http://127.0.0.1:8000/?id=1%27`

Remediation: Use parameterized queries / prepared statements everywhere; disable verbose error output in production.

Manual verification required: Yes

| CVE Correlation

No CVE correlation performed (no versioned services detected, or NVD unavailable).

| Methodology

1. Authorization confirmed by operator before any active module ran.
2. Passive/DNS reconnaissance (WHOIS, RDAP, DNS records, certificate-transparency subdomain discovery).
3. Port and service enumeration (native TCP-connect scan, or Nmap if installed).
4. HTTP/HTTPS reconnaissance, TLS analysis, and technology fingerprinting.
5. Bounded same-host web crawl and endpoint/parameter inventory.
6. Static JavaScript analysis (no code execution).
7. Content discovery with soft-404 baseline filtering.
8. Non-destructive vulnerability indicator checks (headers, cookies, disclosure, injection indicators).
9. Conservative CVE correlation against the NVD database.
10. Evidence-weighted risk scoring and reporting.

This methodology mirrors, at a smaller scale, how commercial scanners (Nessus/OpenVAS/Burp/Nuclei) structure an automated assessment before human validation.

Tool Versions

- nmap: not used
 - ffuf: not used
 - nikto: not used
-